

Table of Contents

Cisco Secure Workload — NY DFS 23 NYCRR Part 500

Reference Design | Covered Entities (Banks, Insurers, Financial-Services Licensees)

Version: 1.0

Framework: New York State Department of Financial Services — Cybersecurity Requirements for Financial Services Companies (23 NYCRR Part 500), as amended (Second Amendment effective 1 November 2023)

Use Case: Covered workload visibility, nonpublic information (NPI) segmentation, access privilege evidence, monitoring, vulnerability management, audit trail, and incident response support

Framework version note. This reference design references 23 NYCRR Part 500 as amended on 1 November 2023 (the "Second Amendment"). Several requirements have phased transition dates through 2024–2025 (e.g. 500.7 access privileges; 500.13 asset management; 500.14 monitoring; 500.15 encryption; 500.17 notice provisions). Confirm the applicable effective date for each requirement against the DFS published rule.

CSW UI navigation note. Cisco does not yet publish Part 500-specific CSW UI navigation; framework-specific paths are on the product roadmap. This reference design describes CSW *capabilities* and the *evidence artifacts* they produce.

Reader's Guide

Who this is for. Covered entities under 23 NYCRR Part 500 (banks, mortgage bankers/brokers, insurance companies, licensed lenders, money transmitters, virtual currency businesses, etc.); the CISO designated under §500.4; risk, audit, and compliance leaders preparing for the annual notice of compliance (§500.17(b)) and the senior officer / board-of-directors certification or acknowledgement.

Questions this reference design helps you answer:

- *Can I show the cybersecurity program (§500.2) operating across covered workloads and NPI-bearing applications, with evidence beyond a point-in-time sample?*
- *Can I show access privileges (§500.7) are restricted to least privilege at the workload-to-workload layer, not just at the identity layer?*
- *Can I produce a workload-level audit trail (§500.6) sufficient to detect and respond to a Cybersecurity Event?*
- *Can I evidence asset management (§500.13) for in-scope information systems?*

- *If a Cybersecurity Event occurs, can I rebuild the affected-systems timeline needed for §500.17(a) 72-hour notification scoping?*

What you'll need. Current information system inventory, NPI-bearing application list, third-party service provider register (§500.11), vulnerability management process (§500.5), incident response plan (§500.16), monitoring approach (§500.14), and the CISO function's reporting cadence.

Where to start. Sections 1–4 if you are scoping; 5–7 if you are designing and simulating policy; 9–10 if you are preparing for the annual §500.17(b) notice of compliance or the senior officer certification within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Covered-system workload visibility
- NPI application scope with continuous inventory
- Third-party service-provider egress monitoring

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

23 NYCRR Part 500 is a prescriptive cybersecurity rule. It defines a Cybersecurity Program (§500.2), Cybersecurity Policy (§500.3), CISO role (§500.4), and a set of technical and operational requirements covering vulnerability management, audit trail, access privileges, application security, risk assessment, third-party service providers, MFA, asset management, monitoring, encryption, incident response, and notification obligations.

CSW can support **technical evidence** for the workload-level dimensions of §500.2 (program), §500.5 (vulnerability management), §500.6 (audit trail), §500.7 (access privileges), §500.13 (asset management), §500.14 (monitoring), and §500.16 (incident response). CSW does **not** replace the CISO function, written policies, MFA / IAM enforcement, encryption programmes, the risk assessment itself, the 72-hour notification decision (§500.17(a)), or the senior officer certification.

Part 500 Section Map and CSW Relevance

Section	Topic	CSW relevance
§500.2	Cybersecurity Program	Workload telemetry feeding the program; CSW outputs are

Section	Topic	CSW relevance
		program inputs, not the program itself
§500.3	Cybersecurity Policy	Out of scope (governance)
§500.4	CISO	Out of scope (role)
§500.5	Vulnerability Management	CVE / package exposure with reachability context
§500.6	Audit Trail	Workload-level flow + process telemetry retained over the required window
§500.7	Access Privileges and Management	Workload-to-workload allowlist + audit; complements identity-layer privilege management
§500.8	Application Security	Out of scope for code-level controls; CSW can show application reachability and dependencies
§500.9	Risk Assessment	Workload reachability + vulnerability context as input to the assessment
§500.11	Third-Party Service Provider Security Policy	Outbound flow visibility to third-party endpoints
§500.12	MFA	Out of scope (identity control)
§500.13	Asset Management and Data Retention	Workload inventory; scope + label evidence
§500.14	Monitoring and Training	Continuous workload monitoring; alerts and anomaly indicators
§500.15	Encryption	Detection of plaintext flows on regulated paths
§500.16	Incident Response and BCDR Plans	Forensic flow / process telemetry; impact scoping
§500.17	Notices to Superintendent	Affected-systems scoping inputs (decision is governance)

2. Pre-Deployment Checklist

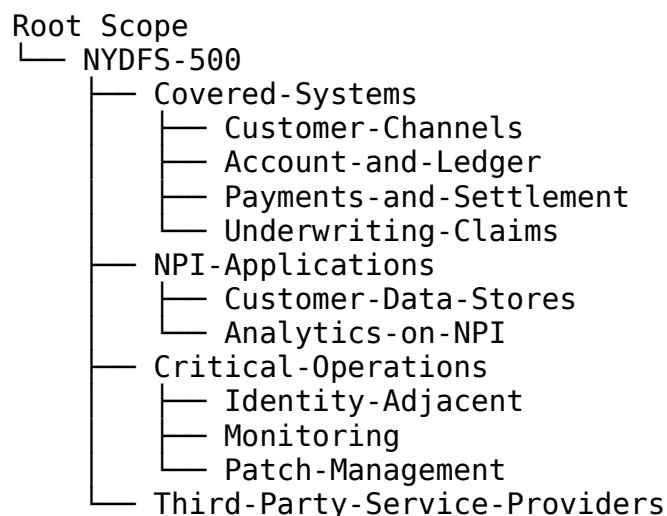
- ☐ CSW cluster provisioned
 - ☐ Sensor compatibility verified for Linux / Windows covered workloads
 - ☐ Cloud accounts connected via CSW cloud connectors where covered workloads run in cloud
 - ☐ Covered entity scope statement reviewed (which information systems are in scope of §500)
 - ☐ NPI inventory reviewed with information owners
 - ☐ Third-party service provider register available (§500.11)
 - ☐ Stakeholders identified: CISO, application owners, internal audit
 - ☐ Evidence retention period agreed and consistent with §500.6 expectations
-

3. Phase 1 — Sensor & Connector Deployment (Days 1–5)

- Install software sensors on representative covered workloads in monitoring mode
 - Connect cloud accounts as read-only CSW cloud connectors for in-scope cloud workloads
 - Apply Day-1 labels: application, env, data_class, npi, criticality, owner, compliance=nydfs-500
 - Maintain a cannot-instrument register for managed SaaS and appliances; the register is evidence
 - Retain a Phase-1 sensor inventory baseline (status, version, last check-in)
-

4. Phase 2 — Scope & Asset Management (Days 6–10) — supports §500.13

4.1 Suggested Scope Architecture



4.2 Inventory Filters

Filter: NPI-Application-Candidates

- Tag: data_class = np_i
- Listening port: 1521, 3306, 5432, 1433, 27017
- Hostname / application pattern matches NPI app names

Filter: Third-Party-Service-Provider-Edges

- Destination outside on-prem and cloud allow-lists
- Tag: managed_by = vendor

4.3 Labeling Strategy

Label key	Example values	Why it matters for Part 500
np_i	true, false	Anchor for §500.7 / §500.13 / §500.15
data_class	np_i, customer, internal, public	Required to evidence handling and protection of NPI
criticality	critical, important, standard	Risk-tiering for §500.9 and §500.13
application		Connects workloads to applications named in the program
owner		Accountability
compliance	nydfs-500	Filters CSW evidence to Part 500 scope

Workload inventory + labels + scope membership = §500.13 asset management evidence.

5. Phase 3 — Application Dependency Mapping (Days 11–21)

Run ADM for each scope across a 2-week-minimum window that covers business cycles. Document:

Question	Part 500 section
Which workloads receive connections from outside Covered-Systems?	§500.7 (access privileges)
Which database connections are plaintext?	§500.15 (encryption)
Which workloads reach Third-Party-Service-Providers?	§500.11

Question	Part 500 section
Are there unexpected lateral flows within NPI-Applications?	§500.7 / §500.14
Which workloads are reached by admin paths?	§500.7 (privileged paths)
Use ADM clusters to confirm or correct <code>npi</code> , <code>data_class</code> , and <code>criticality</code> labels with application owners.	

6. Phase 4 — Policy Development (Days 22–35) — supports §500.7

6.1 Part-500-Aligned Policy Framework

Absolute policies:

DENY Any (default deny inbound)	→ NPI-Applications	
DENY NPI-Applications direct internet egress from NPI)	→ Internet	(no
DENY Corporate-IT only via approved jump paths)	→ NPI-Applications	(admin

Allowlist policies (least privilege):

ALLOW Customer-Channels tcp/443	→ Account-and-Ledger
ALLOW Account-and-Ledger tcp/<db-port-tls>	→ Customer-Data-Stores
ALLOW NPI-Applications tcp/636, tcp/88	→ Identity-Adjacent
ALLOW Jump-Hosts tcp/22, tcp/3389	→ Covered-Systems
ALLOW Covered-Systems tcp/443	→ Monitoring

Catch-all:

LOG Any (unmatched inbound)	→ NPI-Applications
LOG NPI-Applications (unmatched outbound)	→ Any

6.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement	1 week	Enforce obvious

Phase	Mode	Duration	Purpose
3	(high-confidence rules only)	Ongoing	deny rules
	Full Enforcement		Workload allowlist enforced; monthly exception review

Workspace snapshots = §500.7 evidence.

7. Phase 5 — Section Mapping with CSW Evidence

Part 500 section	What CSW produces	How to use it
§500.2	Continuous workload telemetry; periodic evidence pack	Demonstrate program is operating, not just defined
§500.5	Vulnerability + reachability report scoped to NYDFS-500	Risk-based remediation prioritisation evidence
§500.6	Flow + process telemetry retained per retention policy	Audit trail (workload network layer)
§500.7	Policy workspace + enforcement / violation log	Least-privilege evidence at workload-to-workload layer
§500.9	Reachability and exposure inputs	Inputs to the periodic risk assessment
§500.11	Outbound flow summary to third-party endpoints	Reconcile against the third-party register
§500.13	Workload inventory; scope + label export	Asset management and classification evidence
§500.14	Continuous monitoring; alerts; anomaly indicators	Monitoring evidence (network + process layer)
§500.15	Plaintext-flow detection on regulated paths	Detection input only; encryption is enforced by other controls
§500.16	Forensic flow + process search across the incident window	Incident scoping and timeline
§500.17(a)	Affected-systems list,	Scoping input to the 72-

Part 500 section	What CSW produces	How to use it
	time windows, paths	hour notification decision

8. Phase 6 — Vulnerability & Risk Management (§500.5 / §500.9)

Use reachability-weighted CVE data:

Priority 1: Critical CVE on NPI-Applications with inbound reachability

Priority 2: Critical CVE on Covered-Systems

Priority 3: Critical CVE on supporting workloads with reach into NPI-Applications

Document compensating controls in the policy workspace exception register; this register is itself evidence under §500.7 / §500.9.

9. Phase 7 — Monitoring & Alerting (§500.14)

Alert	Trigger	Section
Unauthorised reach to NPI-Applications	Any unapproved source → NPI scope	§500.7
Plaintext on NPI path	HTTP / unencrypted DB protocol from NPI scope	§500.15
Lateral movement inside Covered-Systems	New east-west flow outside baseline	§500.14 / §500.16
External egress from NPI	NPI-Applications → external endpoint not in allow-list	§500.11
Policy violation	Enforced policy block triggered	§500.7
Sensor offline	Agent stops reporting	§500.6 / §500.14 (evidence integrity)

9.2 Forensic Telemetry (§500.16)

For each material incident, retain:

- Flow log scoped to affected workload(s) and time window (with process context)
- Process search output
- Policy workspace state at the time of the incident
- Vulnerability snapshot for the affected workload(s)
- Third-party endpoint reach summary if relevant

10. Reporting & Evidence Collection

10.1 Evidence per Audit / §500.17(b) Cycle (quarterly recommended; annually required)

Evidence item	CSW source area	Section
Workload inventory	Inventory export	§500.13
Scope + label membership	Scope membership export	§500.13
Approved vs. observed flows	ADM workspace export	§500.7 / §500.14
Policy workspace snapshot	Policy workspace export	§500.7
Policy enforcement / violations	Policy analysis output	§500.7 / §500.16
Vulnerability + reachability	Vulnerability report scoped to NYDFS-500	§500.5 / §500.9
Third-party egress summary	Flow search to vendor endpoints	§500.11
Incident timeline sample	Flow + process search	§500.16 / §500.17(a)
Exception register	Policy workspace exceptions list	§500.7 (risk acceptance)

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory hygiene; third-party egress reconciliation
- **Quarterly:** policy workspace review; refresh evidence pack 10.1
- **Annually:** §500.17(b) notice of compliance; senior officer / board acknowledgement; refresh CSW baselines
- **Continuously:** policy drift detection; ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Treating CSW evidence as full §500 compliance	CSW is one technical input; §500.2 program is broader
npi labels missing or inconsistent	Reconcile NPI inventory ↔ CSW labels monthly
Scope set by subnet rather than workload	Use process + label identity
ADM run too short, missing cycle peaks	Minimum 2-week ADM; align to business cycles
Third-party egress not in vendor	Maintain the vendor register; ensure

Pitfall	Mitigation
scope	CSW labels mirror it
§500.17(a) treated as automated	Notification is a CISO/senior-officer decision; CSW provides scoping inputs
Encryption assumed by port number	Confirm by process + observed handshake, not by TCP port

Related Frameworks in This Repository

- [PCI DSS v4.0](#) — cardholder data overlap
- [SOC 2 Type II](#) — many DFS-covered entities also issue SOC 2 reports
- [NIST SP 800-53 Rev 5](#)
- [ISO/IEC 27001:2022](#)

Document prepared for Cisco financial-services engagements regulated by NY DFS. Replace [Customer Name] and any bracketed fields before customer delivery. Validate section references against the current DFS published rule and applicable transition dates.